

Case Study for Assessment 2

Optus Data Breach [1]

Optus is Australia's second-largest mobile carrier, providing about 31% of mobile services. In September 2022, a cyber maintenance failure exposed sensitive customer data.

Initially, Optus announced that the cyber security incident led to the theft of personal information from about 150,000 customers, including names, birth dates, phone numbers, and email addresses. In the following days, Optus found the hacker had accessed between 2.5 million and 9.7 million records. For some customers, the leak included addresses and driver licence, Medicare, or passport numbers.

Optus worked with federal and state government agencies, including the Australian Cyber Security Centre, to decrease the risks to customers. Optus also notified the Office of the Australian Information Commissioner and key regulators.

The breach allegedly occurred due to an unsecured application interface that allowed other devices and systems to access it. The damage to Optus was significant, including substantial spending on remediation and potential compensation for victims. Estimates also suggest a \$1.5 billion loss in Optus's brand value.

A hacker on a dark web forum claimed to have stolen and then deleted the data, but it is not known if this is true. The stolen identities may still surface, putting Optus customers at ongoing risk of identity theft. The incident also impacted government agencies, such as the Department of Transport and Main Roads, which had to replace over 178,000 Queensland driver licences.

This incident has prompted many organisations to re-evaluate the sensitive data they hold, and their business needs for collecting and storing this data. When legally permitted to do so, organisations should consider discarding unnecessary data.

The lesson is clear: if an organisation doesn't hold sensitive customer data, it can't lose it.

No organisation is immune from a cyberattack. To be cyber-resilient, companies must have plans to respond quickly when an attack happens. As this case shows, technical incident response is just one part of the puzzle.

Note - Commonwealth law requires businesses to take reasonable steps to destroy or de-identify personal information when it is no longer needed for any purpose permitted under the Privacy Act. This requirement does not apply if businesses are required or authorised by law to keep it. Please obtain your own legal advice.

Ransom threat: An internet user published data samples on an online forum and demanded a ransom of \$1m (A\$1.5m; £938,000) in cryptocurrency from Optus. The company had a week to pay or the other stolen data would be sold off in batches, the person said. Investigators are yet to verify the user's claims, but some experts quickly said the sample data - which contained about 100 records - appeared legitimate. Sydney-based tech reporter Jeremy Kirk contacted the purported hacker and said the person gave him a detailed explanation of how they stole the data. The user contradicted Optus's claims the breach was "sophisticated", saying they pulled the data from a freely accessible software interface [2].

How Did the Optus Data Breach Happen?

The Optus data breach of September 2022, occurred through an unprotected and publically exposed API. This API didn't require user authentication before facilitating a connection. A lack of an authentication policy meant anyone that discovered the API on the internet could connect to it without submitting a username or password.

Security Flaw 1: Three security flaws can be identified in this setup. The first is a public-facing API (Application Programming Interface). An API should never be public-facing if it facilitates access to sensitive internal data or permits interactions with core business operations. Examples of open APIs that follow best API security practices are the Google Maps API and the Weather API. Any data that's available through these APIs is completely isolated from core business processes, so it's impossible to cause a data breach through these open APIs.

Security Flaw 2: This brings us to Optus' second security flaw. The open API facilitated access to very sensitive customer data. To get a sense of the level of sensitive data this API was granting access to, whenever an Optus customer loads

their account information either via the Optus mobile app or the Optus website, an API such as the one that facilitated the data breach is used to complete the request.

Backend processes call upon sensitive customer records to load a customer profile. This is why the Optus data breach resulted in the compromise of the following types of personal data:

- Driver's License numbers
- Phone numbers
- Dates of birth
- Home addresses

Security Flaw 3: The third and final security flaw in this vulnerability package was the use of incrementing customer identifiers. In the digital world, programs identify customers by a unique sequence of numbers and letters. These are the identifiers that are called upon when a customer loads their account. According to best cybersecurity practices, each customer identifier, or contactID, should be completely unique and unrelated to other identifiers to prevent hackers from discovering the formula that determines each customer ID.

In Optus's case, all customer identifiers differed by an increment of 1. So if one customer had the unique identifier 5567, the next customer in the database could be found with the identifier 5568. When a hacker gains access to a customer database, the first thing they do is cross their fingers and check whether data identifiers increase incrementally. If this is the case, brute force techniques aren't necessary, and the process of stealing data becomes much easier.

When the hacker responsible for the Optus breach gained access to the company's customer database, they were very pleased to find that all customer records were indeed stored with incrementing identifiers. This allowed them to write a script that requested every customer record in the database by simply incrementing each contactID index by one.

With virtually the entire data exfiltration process outsourced to an automated script, the hacker was able to complete the data breach much faster and at a much larger scale than it would have otherwise been possible if unique customer identifiers had been used.

Report Structure

1. **Introduction:** Briefly introduce the Optus breach and the purpose of the report.
2. **Threat Analysis and Defence Strategies:** Describe how the breach occurred and evaluate what defence mechanisms could have prevented it.
3. **Security Implementations:** Explore the existing security flaws and suggest modern best practices and improvements.
4. **Ethical Compliance in ICT Practices**
 - Assess Optus' handling of personal data ethically and legally.
 - Consider issues of data minimisation and accountability.
5. **Recommendations:** Provide specific and practical recommendations for improving data protection and ethical compliance.
6. **Conclusion:** Summarise the main findings of your report.
7. **References:** Use **APA/Harvard referencing style**. Include all sources used in your research.

References

- [1] <https://www.qld.gov.au/community/your-home-community/cyber-security/cyber-security-for-queenslanders/case-studies/optus-data-breach>
- [2] <https://www.bbc.com/news/world-australia-63056838>
- [3] <https://www.upguard.com/blog/how-did-the-optus-data-breach-happen>

